Network Traffic Analysis: SYN Flood Attack Investigation

Case study completed as part of the Google Cybersecurity Professional Certificate

Scenario

A travel agency's public sales website became unreachable after a monitoring system flagged a web server issue. Visitors received connection timeout errors. Packet capture data (Wireshark) was reviewed to identify the cause and assess impact on the organization's network.

Section 1: Attack Identification

Observed symptom: The web server stopped responding to legitimate requests, and clients received connection timeout and 504 Gateway Timeout errors.

Traffic pattern: The capture showed a high volume of TCP SYN packets sent to port 443 from the source IP 203.0.113.0, with no corresponding completion of the three-way handshake. Legitimate client traffic (e.g., 198.51.100.5, 198.51.100.14) completed normal handshakes and HTTP requests earlier in the capture, but subsequent legitimate connections were met with RST or timeout responses as server resources became exhausted.

Attack type: SYN flood attack, a form of denial-of-service (DoS) attack. The source IP repeatedly sent SYN requests without completing the handshake, consistent with a single-source SYN flood rather than a distributed (DDoS) attack, since traffic originated from one dominant IP address rather than a distributed set of sources.

Section 2: Technical Analysis and Impact

Normal TCP three-way handshake:
1. The client sends a SYN packet to initiate a connection.
2. The server responds with a SYN-ACK packet, acknowledging the request.
3. The client responds with an ACK packet, completing the handshake and establishing the connection.

How the attack disrupted this process: The attacking source sent a continuous stream of SYN packets without completing the final ACK step. Each incomplete request forces the server to hold a half-open connection in memory while it waits for a response that never arrives. As these half-open connections accumulated, the server's connection table and processing resources became exhausted, leaving it unable to respond to genuine client requests.

Evidence from the log: 203.0.113.0 sent SYN requests to port 443 dozens of times in rapid succession, without ever returning the ACK needed to complete the handshake. During this same window, legitimate clients such as 198.51.100.5, who did complete a valid handshake and issue an HTTP GET request, still received a 504 Gateway Timeout, showing that the flood had already consumed the server's available resources. Other legitimate clients (198.51.100.16, 198.51.100.7, 198.51.100.22) had their connection attempts closed with RST, ACK responses rather than being served normally.

Organizational impact: The sales website became unavailable to customers and employees, disrupting the business's ability to advertise promotions and process customer inquiries. Extended downtime of this kind can result in lost sales, reduced customer trust, and reputational harm, in addition to the operational cost of incident response.

Immediate response taken: The affected server was taken offline temporarily to recover, and the firewall was configured to block the identified source IP address.

Recommended follow-up mitigations:
• Implement SYN cookies or connection rate limiting on the web server or load balancer to prevent half-open connections from exhausting server resources.
• Deploy a firewall or intrusion prevention system capable of detecting and automatically throttling abnormal SYN traffic patterns.
• Consider a DDoS protection service or CDN in front of the web server, since IP-based blocking alone is not durable against spoofed or rotating source addresses.
• Continue monitoring for a shift from single-source to distributed traffic patterns, which would indicate an escalation to a DDoS attack.